

muni

관리자 가이드

설치·설정·운영·장애 대응

버전	v0.39.0
작성일	2026-09-15
문서	관리자 가이드

muni 관리자 가이드

muni 를 설치하고, 설정하고, 계정을 만들고, 사고가 났을 때 확인하는 사람을 위한 안내입니다. 화면을 쓰는 법은 [사용자 가이드](#)에 있고, 백업·복구·키 교체·퇴사자 정리 같은 운영 절차의 상세는 [운영 안내](#)에 있습니다. 이 문서는 그 둘을 잇는 자리입니다.

화면은 muni v0.36.0 을 데모 데이터로 채워 실제로 찍은 것입니다(방문 추적 탭만 그 기능이 들어간 다음 빌드에서 찍었습니다).

1. 구성 요소

muni 는 컨테이너 하나입니다. Go 바이너리 안에 React 번들이 들어 있고, PDF 를 그릴 headless Chromium 과 Noto CJK 글꼴이 이미지에 함께 들어 있습니다. 런타임에 Redis·오브젝트 스토리지·검색 엔진이 필요하지 않습니다.

구성 요소	필수	무엇을 하나
muni 컨테이너	O	웹 UI, REST API(/api/v1), MCP(/mcp), 공동편집 WebSocket, Import·Export
PostgreSQL 15 이상	O	문서·버전·댓글·첨부·설정·감사 로그. 첨부까지 데이터베이스 안에 있습니다
Keycloak	-	OIDC SSO. 붙이지 않으면 로컬 로그인만 씁니다
OpenAI 호환 게이트웨이	-	AI 기능. 끄면 AI 패널이 비활성으로 보입니다
SMTP 서버	-	계정 안내·알림 메일
Ptium	-	발표자료 생성 연동

주고받는 것은 이렇습니다. 브라우저 ↔ muni 는 HTTP 와 WebSocket(/api/v1/collab/{id}), muni ↔ PostgreSQL 은 DSN 한 줄, 나머지 연동은 모두 **서비스 관리** → **서비스 설정**에 저장된 주소로 muni 가 나가는 방향입니다. muni 가 밖에서 들어오는 연결을 받는 포트는 8080 하나뿐입니다.

2. 설치

릴리스 자산은 이미지 하나를 담은 tar.gz 입니다. 파일명과 이미지 태그가 같은 규칙을 씁니다.

```
asset: muni-v0.36.0.tar.gz
image: muni:v0.36.0
```

준비

- PostgreSQL 15 이상. DSN 계정에는 최초 실행 때 schema 와 pgcrypto , citext extension 을 만들 권한이 필요합니다.

- 디스크: 데이터베이스에 첨부까지 들어가므로 문서량이 아니라 첨부량으로 잡습니다.
- TLS 는 사내 ingress·reverse proxy 에서 끝내는 구성을 권장합니다.

올리기

```
gzip -dc muni-v0.36.0.tar.gz | docker load
cp .env.example .env
# .env 의 네 값을 안전한 값으로 바꿉니다
openssl rand -base64 32          # ENCRYPTION_KEY 에 넣을 값
docker compose -f compose.example.yaml --env-file .env up -d
```

compose.example.yaml 의 image: 태그를 받은 버전(muni:v0.36.0)으로 맞춘 뒤 올립니다. 기동하면 마이그레이션이 자동으로 적용되고, BOOTSTRAP_ADMIN 으로 최초 관리자 계정이 만들어 집니다. 계정이 이미 있으면 bootstrap 값은 그 계정을 덮어쓰지 않습니다.

```
curl -fsS http://127.0.0.1:8080/healthz # 살아 있는가
curl -fsS http://127.0.0.1:8080/readyz # 요청을 받을 준비가 되었는가
docker compose logs -f muni
```

브라우저로 http://<host>:8080/login 에 들어가 BOOTSTRAP_ADMIN 계정으로 로그인하면 끝입니다. 첫 로그인 뒤 개인 설정 → 프로필에서 비밀번호를 바꾸세요.

자원과 경로

항목	값
포트	8080 (HTTP 하나. 컨테이너가 여는 유일한 포트)
볼륨	없음 — 상태는 전부 PostgreSQL 에 있습니다
tmpfs	/tmp 512MB. PDF 렌더링이 여기에 임시 디렉터리와 Chromium HOME 을 만듭니다
파일 시스템	read_only: true 로 돌립니다. 위 tmpfs 설정은 유지하세요
사용자	비 root(uid/gid 65532), 모든 capability drop
헬스체크	curl --fail http://127.0.0.1:8080/healthz (이미지에 내장)
권장 자원	request 100m CPU / 192MiB, limit 2 CPU / 2GiB (deploy/kubernetes/muni.yaml 기준)

Kubernetes 로 올린다면 deploy/kubernetes/muni.yaml 이 위 설정을 그대로 담은 예제입니다. Chromium 한 프로세스가 수백 MB 를 쓰므로 메모리 한도는 MUNI_PDF_CONCURRENCY 와 함께 잡으세요.

3. 설정

환경 변수

애플리케이션이 환경 변수로 받는 값은 **아래가 전부**입니다. 나머지 운영 설정은 모두 화면에서 바꿉니다.

변수	필수	기본값	설명
POSTGRES_DSN	O	없음	PostgreSQL 접속 문자열. 예: <code>postgres://muni:...@postgres.internal:5432/muni?sslmode=require</code>
BOOTSTRAP_ADMIN	O	없음	최초 관리자의 이메일 또는 3자 이상 아이디. 예: <code>admin@example.com</code>
BOOTSTRAP_ADMIN_PASSWORD	O	없음	최초 관리자 비밀번호. 12자 이상 . 예: <code>replace-with-at-least-12-characters</code>
ENCRYPTION_KEY	O	없음	설정 secret 과 사용자 data key 를 봉인하는 base64 32바이트 master key. <code>openssl rand -base64 32</code> 로 만듭니다
MUNI_CHROMIUM_PATH	-	자동 탐색	PDF Export 에 쓸 브라우저 실행 파일. 비우면 <code>chromium · chromium-browser · google-chrome · google-chrome-stable · chrome</code> 순으로 찾습니다
MUNI_PDF_CONCURRENCY	-	2	동시에 띄울 Chromium 수 (1~32). 자리를 60초 넘게 기다리면 재시도 안내와 함께 거절합니다

값이 빠지면 기동하지 않고 `required environment variables are missing: ...` 을 남기고 멈춥니다.

`ENCRYPTION_KEY` 가 base64 32바이트가 아니면 `ENCRYPTION_KEY must be a base64-encoded 32-byte key` 로 멈춥니다.

`ENCRYPTION_KEY` 를 잃으면 봉인된 비밀값은 복구할 수 없습니다. **데이터베이스 백업과 다른 곳에 보관하세요.** 잃었을 때 할 수 있는 일은 [운영 안내](#)에 적혀 있습니다.

서비스 설정 화면

m muni

SERVICE ADMIN

☰ 운영 현황

⚙ 서비스 설정

👤 사용자 관리

📁 워크스페이스

📄 문서 관리

🔑 권한 정책

🔍 AI 호출 감사

🛡 감사 로그

← 문서로 돌아가기

muni 서비스 관리

서비스 설정

전체 저장

일반

Keycloak OIDC

AI

검토·승인

보안·내보내기

발표자료 연동

메일 알림

보존 정책

일반 설정

서비스 표시 이름과 기본 화면 동작을 정합니다.

서비스 이름

muni

기본 언어

ko-KR

목록 페이지 크기

30

☒ 로컬 로그인 허용

서비스 설정 — 일반·Keycloak OIDC·AI·검토·승인·보안·내보내기·발표자료 연동·메일 알림·보존 정책 탭

탭	여기서 정하는 것
일반	서비스 표시 이름, 기본 언어, 목록 페이지 크기, 로컬 로그인 허용 여부
Keycloak OIDC	issuer URL·client ID·client secret, 자동 프로비저닝과 기본 역할, 로그인 화면 없이 바로 들어가는 자동 로그인(기본 꺼짐, 아래). Discovery 연결 테스트가 있습니다
AI	OpenAI 호출 base URL (/v1 까지)·API key·model·timeout·최대 토큰. 상한은 시스템 상한 262144 와 관리자 상한 중 작은 값입니다
검토·승인	결제 흐름 사용 여부, 필요한 승인 수, 본인 승인 허용 여부. 꺼 두면 사용자 메뉴에 「검토 및 승인」이 나타나지 않습니다
보안·내보내기	세션 유지 시간, API 키 최대 수명, 공개 링크 허용, 업로드 크기 상한(1~1024MB), 읽기 감사 로그, PDF·DOCX 내보내기 허용
발표자로 연동	Ptium 주소와 API key. 저장 전에 연결 테스트를 할 수 있습니다
메일 알림	사내 SMTP 릴레이, 보낼 이벤트 스위치, 시험 발송, 발송 기록. 기본은 꺼짐입니다. 아래 에 따로 적었습니다
보존 정책	휴지통·버전·감사 로그·AI 감사 로그를 며칠 뒤 지울지. 버전은 최소 5개를 남깁니다
방문 추적	어떤 화면이 쓰이는지 세는 스크립트를 페이지에 붙일지, 어느 수집기로 보낼지. 기본은 꺼짐입니다. 아래 에 따로 적었습니다
문서 넘기기	문서를 내려받지 않고 바로 보낼 수 있는 사내 서비스와, 문서를 받아 줄 서비스의 허용 목록. 기본은 비어 있습니다. 아래 에 따로 적었습니다

비밀값(AI API key, OIDC client secret, SMTP 비밀번호, Ptium API key)은 `ENCRYPTION_KEY` 로 봉인해 저장하며 화면에 다시 보여 주지 않습니다.

Keycloak 연동 순서는 confidential client 를 만들고 Redirect URI 에 `https://<muni-host>/api/v1/auth/oidc/callback` 을 등록한 뒤, 이 탭에 issuer·client ID·client secret 을 넣고 연결 테스트 → 활성화 → 저장입니다. Endpoint 는 discovery 로 결정하고 scope 기본 값은 openid profile email 입니다.

자동 로그인(silent SSO)

Keycloak 에 이미 로그인한 사람이 muni 를 열면 로그인 화면을 거치지 않고 바로 본 화면으로 들어가게 할 수 있습니다. Keycloak OIDC 탭의 「**Keycloak에 이미 로그인되어 있으면 로그인 화면 없이 바로 들어가기 (prompt=none)**」가 그 설정 (`oidc.auto_login`)이고 **기본은 꺼짐**입니다. 꺼진 설치에서는 아무것도 달라지지 않습니다.

설정	뜻
<code>oidc.enabled</code>	SSO 자체. 이것이 꺼져 있으면 자동 로그인도 없습니다
<code>oidc.auto_login</code>	세션이 없는 브라우저가 보호된 화면을 열 때 Keycloak 에 조용히 한 번 물어봅니다. 기본 꺼짐

어떻게 동작하는가. 세션 없는 브라우저가 문서나 홈 같은 보호된 화면을 열면, 로그인 화면을 그리는 대신 브라우저 창 전체가 `/api/v1/auth/oidc/start?prompt=none&return_to=<원래 주소>` 로 이동합니다. `prompt=none` 은 Keycloak 에 "이미 있는 세션으로만 답하라" 고 요구하는 OIDC 표준 매개변수라 **화면을 절대 그리지 않습니다** — 세션이 있으면 인가 코드가 바로 돌아와 평소 로그인과 같이 끝나고 원래 주소로 돌아가며, 없으면 `error=login_required` 가 돌아옵니다. 이것은 실패가 아니라 평범한 대답이어서 muni 는 오류 없이 로그인 화면(`/login?sso=none`)으로 보냅니다. 숨은 `iframe` 이 아니라 최상위 이동이므로 서드파티 쿠키를 막은 브라우저에서도 동작하고, Keycloak 이 프레임을 허용하는 지 신경 쓰지 않아도 됩니다.

한 번만 시도합니다. 거절을 받고 다시 시도하면 브라우저가 Keycloak 과 muni 사이를 끝없이 오가며 사용자는 깜빡이는 화면만 봅니다. 막는 장치를 세 겹으로 두었습니다.

- 한 탭 세션에 한 번 — 시도했다는 표시를 탭의 `sessionStorage` 에 남깁니다. 새 탭은 다시 시도하고, 거절된 뒤 새로 고치면 시도하지 않습니다.
- 스스로 로그아웃했으면 하지 않습니다 — 로그아웃 직후 다시 조용히 로그인되면 로그아웃이 고장 난 것처럼 보입니다. 다시 세션이 생기면 억제가 풀립니다.
- 거절을 주소에 남깁니다 — 콜백이 `login_required` 를 받으면 `/login?sso=none` 으로 보내므로 브라우저 저장소가 지워졌더라도 그 주소에서는 다시 시도하지 않습니다.

사생활 보호 모드처럼 `sessionStorage` 를 읽지 못하는 브라우저는 "이미 시도했다" 로 칩니다. 로그인·콜백 경로와 `/api` · `/mcp` · `/healthz` 같은 화면이 아닌 경로에서는 시도하지 않습니다.

서버가 설정을 지킵니다. `auto_login` 이 꺼져 있으면 누가 주소에 `?prompt=none` 을 붙여 부르더라도 서버가 조용히 평범한 로그인으로 바꿉니다. 깊은 링크의 `return_to` 는 `/` 로 시작하고 `//` 로 시작하지 않는 경로만 받아, 이 흐름이 밖으로 내보내는 발판이 되지 않습니다.

방문 추적

m muni

SERVICE ADMIN

운영 현황

서비스 설정

사용자 관리

워크스페이스

문서 관리

키 권한 정책

AI 호출 감사

감사 로그

←

문서로 돌아가기

muni 서비스 관리

방문 추적 켜기

제공자

Momento (사내 수집기)

방출 자리

<head> 끝

Momento 수집기 주소

https://momento.internal

사내에서 띄운 Momento 의 주소입니다. 데이터가 밖으로 나가지 않는 유일한 선택지입니다.

사이트 id

muni

muni 를 거쳐 보내기 (같은 오리진 프록시, /momento/*)

프록시를 거치면 브라우저는 muni 하고만 이야기하므로 보안 정책에 바깥 주소가 등장하지 않습니다. 끄면 수집기 주소가 정책에 더해집니다.

추가로 허용할 출처

코드에서 자동으로 읽지 못한 주소를 심프로 구분에 적습니다. 아래 차단 목록의 「허용」이 여기에 더합니다.

서비스 관리 화면에서도 추적

muni 의 보안 정책은 자기 오리진의 스크립트만 허용합니다. 추적 코드는 요청마다 새로 만든 nonce 를 달고 나가며, 정책을 'unsafe-inline' 으로 풀지 않습니다. 쿼리 동안 브라우저가 차단한 주소가 아래에 쌓입니다.

정책이 차단한 출처

목록 비우기

출처	지시어	횟수	
https://pixel.internal	img-src	1	허용

서비스 설정 → 방문 추적 — Momento 수집기 설정과, 정책이 차단한 출처 목록의 「허용」 단추

어떤 화면이 실제로 쓰이는지 세려면 방문 추적 스크립트를 페이지에 붙입니다. 기본은 꺼짐이라 새로 설치한 곳에서는 아무것도 달라지지 않고, 커더라도 muni 가 보내는 것은 스크립트가 세는 쪽 번호와 경로뿐이며 문서 내용은 담기지 않습니다. 설정은 저장소에 두고 화면에서 바꾸므로 수집기 주소가 바뀌어도 다시 배포하지 않습니다.

설정	뜻
방문 추적 켜기	꺼짐이 기본값입니다. 켜야 붙습니다
제공자	Momento · Matomo · Google Analytics 4 · Google Tag Manager · 직접 붙여넣기 · 없음
Momento 수집기 주소 · 사이트 id	사내에 띄운 Momento 수집기의 주소와 사이트 id
muni 를 거쳐 보내기	Momento 만. muni 가 /momento/* 를 수집기로 넘기고 스니펫은 data-endpoint="/momento" 로 나갑니다. 기본으로 켜져 있습니다
측정 ID · Matomo 주소 · 사이트 id	GA4·GTM 과 Matomo 의 것. 구글 쪽은 폐쇄망에서 달지 않습니다
추적 코드	직접 붙여넣기. 8KB 를 넘으면 저장되지 않습니다
추가로 허용할 출처	코드에서 자동으로 읽지 못한 주소를 관리자가 더하는 자리. 아래 차단 목록의 「허용」이 여기에 더합니다
서비스 관리 화면에서도 추적	기본은 아니오. 관리자가 누른 것은 대개 알고 싶은 방문이 아닙니다
넣을 자리	<head> 끝 또는 <body> 끝

Momento 를 먼저 고르세요. Momento 는 사내 자체 호스팅 수집기라 데이터가 밖으로 나가지 않는 유일한 선택지입니다. 「muni 를 거쳐 보내기」를 켜 두면(기본) 브라우저는 muni 하고만 이야기하고 muni 가 수집기로 넘기므로 아래의 보안 정책에 바깥 주소가 아예 등장하지 않습니다. 넘길 때 방문자의 세션 쿠키는 떼고 방문자 주소는 X-Forwarded-For 로 붙입니다. 프록시는 Momento 를 고르고 켜 둔 동안에만 답하며, 다른 어디로도 중계하지 않습니다.

콘텐츠 보안 정책(CSP)과 왜 스니펫을 그냥 붙일 수 없는가

muni 의 모든 페이지는 script-src 'self' 로 잠긴 콘텐츠 보안 정책을 달고 나갑니다. 자기 오리진의 스크립트만 실행하므로 추적 코드를 그냥 끼워 넣으면 브라우저가 **조용히** 막고, 관리자는 수집기가 비어 있는 이유를 알 길이 없습니다. muni 는 그래서 다음을 함께 합니다.

- 요청마다 nonce** — 페이지를 낼 때마다 새 nonce 를 만들어 스니펫의 모든 <script> 태그에 붙이고 같은 값을 정책의 script-src 에 넣습니다. 정책을 'unsafe-inline' 으로 풀지 않습니다 — 한 번 풀면 앱의 모든 인라인 스크립트가 함께 허용되고, 추적을 끈 뒤에도 느슨한 채 남기 때문입니다.
- 출처는 코드에서 읽습니다** — 추적 도구는 자기 주소를 로더 안에 적어 둡니다. 붙여 넣은 코드에서 http(s) 주소를 끊어 script-src · connect-src · img-src 에 더합니다. Momento(직접 연결)·Matomo 는 적어 둔 주소, GA4·GTM 은 구글의 알려진 주소가 더해집니다.
- 차단된 것을 기록합니다** — 추적이 켜진 동안에만 정책에 report-uri /api/v1/tracking/csp-report 를 넣습니다. 브라우저가 막은 것을 신고하면 출처와 지시어를 메모리에 기억하고(서로 다른 출처 100개까지, 데이터베이스에는 쓰지 않습니다) 이 탭의 「정책이 차단한 출처」에 보여 줍니다. 「허용」을 누르면 그 출처 하나가 「추가로 허용할

출처」에 더해지고, 화면을 새로 고치면 정책에 들어갑니다. 「목록 비우기」로 지운 뒤 다시 새로 고쳐 아직 막히는 것이 있는지 봅니다.

추적을 끄면 정책은 예전 그대로 좁아집니다. `/api/*` · `/mcp` · `/healthz` · `/readyz` · `/metrics` · `/momento/*` 같은 화면이 아닌 경로에는 스니펫이 붙지 않고, 정책은 오히려 더 좁은 `default-src 'none'` 입니다. 「서비스 관리 화면에서도 추적」이 꺼져 있으면 `/admin` 아래를 직접 열었을 때 스니펫이 빠지지만, 다른 화면에서 메뉴로 넘어온 경우에는 이미 실행된 스크립트가 그대로 남습니다 — 화면 전환이 페이지를 다시 받지 않기 때문입니다.

설정 순서는 제공자와 주소를 넣고 「전체 저장」 → 아무 문서 화면을 새로 고침 → 수집기에서 방문이 들어오는지 확인 → 들어오지 않으면 이 탭의 차단 목록을 보고 「허용」 → 다시 새로 고침입니다.

문서 넘기기

생각은 umm 의 캔버스에서 시작해 muni 의 문서가 되고 ptium 의 슬라이드가 되어 weekly 의 보고로 들어갑니다. 단계마다 사람이 파일을 내려받아 다시 올리지 않도록, muni 는 사내 서비스 표준 (HANDOFF-STANDARD) 대로 다른 서비스로 보내기와 다른 서비스에서 받기를 둘 다 합니다. muni 는 `markdown` 과 `docx` 를 보내고 `markdown` 을 받습니다.

서비스끼리 서로의 자격 증명을 들고 있지 않습니다. 보내는 쪽이 5분 동안 한 번만 쓸 수 있는 표(claim) 를 발급하고, 받는 쪽이 표를 들고 원본에서 직접 받아 갑니다. 표는 그 사람이 읽을 수 있는 그 문서 하나에만 묶이고, 해시로만 저장되며, 요청 로그와 감사 로그 어디에도 적히지 않습니다.

기본은 비어 있습니다. 허용 목록이 비어 있는 동안에는 문서 화면의 내보내기 메뉴에 「...으로 보내기」가 나타나지 않고, 다른 서비스가 보낸 문서도 받지 않습니다 — 새로 설치한 곳에서는 아무것도 달라지지 않습니다.

설정	뜻
주소 (오리진)	상대 서비스의 <code>https://호스트</code> 까지. 경로·쿼리 없이 적습니다. 대소문자는 가리지 않고, 포트가 다르면 다른 서비스입니다
이름	메뉴에 보일 이름. 비우면 호스트가 보입니다
그 서비스가 받는 형식	표준의 형식 표에서 그 서비스의 「받는다」 칸. muni 가 보내는 <code>Markdown</code> · <code>DOCX</code> 중 그 서비스가 받는 것만 체크합니다. 둘 다 아니면 보낼 곳으로 나오지 않습니다

같은 목록이 양쪽에 다 쓰입니다 — 여기 적은 서비스로만 보내고, 여기 적은 주소에서만 받습니다. 상대 서비스의 허용 목록에도 이 muni 의 주소(브라우저가 muni 에 닿는 그 주소, `X-Forwarded-Proto` 를 지킵니다)를 같은 방식으로 적어야 양쪽이 이어집니다. 표준의 표대로면 ptium 과 weekly 는 `Markdown` · `DOCX` 를, muni 는 `Markdown` 을 받고, kanpic 과 umm 은 muni 가 보내는 형식을 받지 않으므로 적어도 보낼 곳으로 나오지 않습니다. `DOCX` 는 「보안·내보내기」의 `DOCX` 내보내기가 켜져 있을 때만 보냅니다.

받는 쪽이 지키는 것. `/handoff?source=...&claim=...` 로 들어온 `source` 는 밖에서 온 값입니다. 그대로 받아 오면 muni 가 사내 아무 주소나 대신 끊어 오는 도구가 되므로:

- 허용 목록에 없는 `source` 는 아무것도 요청하지 않고 거절합니다. 호스트가 같아도 경로가 붙어 있으면 오리진이 아니므로 거절합니다.

- 리다이렉트는 따라가지 않습니다. 상대가 다른 곳으로 넘기려 하면 그 자리에서 멈춥니다.
- 받는 크기는 **25MB**, 시간은 **30초**가 상한이고, 넘으면 중간에 끊습니다.
- 응답의 Content-Type 이 `text/markdown` 이 아니면 본문을 읽지 않고 버립니다.
- 받은 문서는 그 사람의 **개인 워크스페이스**에 만들어지고, 첫 버전의 사유에 `handoff:<출처>` 가, 감사 로그에 `HANDOFF_RECEIVE` 와 출처·파일 이름이 남습니다. 어느 캔버스에서 온 문서인지 나중에 물어볼 수 있습니다.

실패하면 JSON 이 아니라 사람이 읽을 화면이 나옵니다 — 허용되지 않은 서비스(403), 표가 만료됐거나 이미 쓰임(404), 읽을 수 없는 형식(415), 너무 큼(413), 상대가 응답하지 않음(502). 로그인 없이 보냈다가 같은 주소로 돌아옵니다.

보내는 쪽. 문서 화면의 내보내기 메뉴에서 「<이름>으로 보내기 (Markdown)」을 고르면 새 탭에서 상대 서비스의 `/handoff` 가 열리고, 상대가 표를 들고 muni 의 `GET /api/v1/handoff/claims/{claim}` 에서 문서를 받아 갑니다. 표를 만든 순간의 문서가 나가며, 받아 가는 순간 표는 사라집니다. 감사 로그에는 `HANDOFF_ISSUE` (발급)와 `HANDOFF_SERVE` (내줌)가 문서 ID 와 형식으로 남고, 표 자체는 남지 않습니다.

메일 알림

검토를 기다리는 문서, 결재 결과, 댓글에서 나를 부른 것, 곧 만료될 API 키 — 사람이 알아야 할 일은 muni 안에서 알림으로 생기지만, muni 를 열지 않으면 닿지 않았습니다. 사내 서비스 표준 (MAIL-STANDARD)대로 **사내 SMTP 릴레이**로 그 알림을 메일로 보냅니다. 릴레이 주소로 사내 메일 서비스(`postra`)를 가리키면 알림이 밖으로 나가지 않습니다.

기본은 꺼짐입니다. 새로 설치한 곳에서는 아무것도 달라지지 않습니다. 켜도 릴레이 주소와 보내는 주소가 없으면 보내지 않습니다.

설정	기본 값	뜻
<code>mail.enabled</code>	꺼짐	관리자가 켜니다
<code>mail.smtp_host</code>	—	사내 릴레이 주소
<code>mail.smtp_port</code>	25	사내 릴레이는 대개 25
<code>mail.security</code>	auto	auto 는 릴레이가 STARTTLS 를 알리면 올리고 아니면 그대로 보냅니다. none · starttls · tls 로 못 박을 수 있고, 465 포트는 tls 로 봅니다
<code>mail.skip_tls_verify</code>	꺼짐	릴레이 인증서가 사설 인증기관일 때만
<code>mail.username</code> · <code>mail.password</code>	빈 값	인증 없는 릴레이가 흔하므로 선택 사항입니다. 계정 정보는 암호화된 연결로만 보내며, 릴레이가 TLS 를 주지 않으면 계정을 비워야 합니다
<code>mail.from_address</code> · <code>mail.from_name</code>	—	보내는 사람. 주소를 비우면 계정 주소를 씁니다
<code>mail.base_url</code>	—	메일 속 링크가 가리킬 muni 주소. 비우면 링크 없이 보냅니다
<code>mail.timeout_seconds</code>	10	
<code>mail.notify_approval_request</code>	켜짐	검토할 문서가 생겼거나 결재 차례가 되었을 때
<code>mail.notify_approval_decision</code>	켜짐	내가 올린 문서가 승인·반려되었을 때
<code>mail.notify_mention</code>	켜짐	댓글에서 나를 @ 로 불렀을 때
<code>mail.notify_api_key_expiring</code>	켜짐	내 API 키가 7일 안에 만료될 때. 키마다 한 번만

키 이름은 다른 사내 서비스(kanpic 등)와 같습니다. 화면에서 바꾸며, 비밀번호는 저장한 뒤 화면에 다시 나오지 않고 (「설정됨」만 보입니다) 로그에도 남지 않습니다.

보내는 것과 보내지 않는 것. 이 메일이 오지 않으면 누군가 손해를 보거나 화면을 계속 새로 고치게 되는 네 가지만 보냅니다. 「무언가 바뀔」은 보내지 않습니다 — 첫 주에 너무 많이 오면 사람들은 규칙을 만들어 통째로 버리고, 그러면 정말 필요한 알림도 함께 버려집니다. 같은 이유로:

- 자기가 한 일은 자기에게 가지 않습니다. 검토 요청은 올린 사람을, 멘션은 쓴 사람을 뺍니다.
- 한 사람에게 여러 알림이 쌓이면(댓글 하나에 두 번 불렀거나, 같은 1분 안에 여럿) **한 통으로 묶습니다.** 제목은 「[muni] 첫 제목 외 N건」이고 본문에 차례로 적힙니다.
- 문서 내용은 담지 않습니다. 알림 메일이 문서를 실어 나르면 받는 사람이 메일을 어디로 전달하든 그 내용도 함께 갑니다.
- 받는 주소는 계정의 이메일입니다. 메일 기능이 따로 명부를 갖지 않으므로 계정에 이메일이 없거나 비활성이면 그 사람에게는 가지 않습니다.

요청을 막지 않습니다. 메일은 1분마다 한 번 배경에서 보냅니다. 릴레이가 느리거나 죽어 있어도 댓글을 다는 일, 결재를 올리는 일은 평소처럼 끝나고, 실패한 알림은 하루 동안 세 번까지 다시 시도합니다.

시험 발송. 「내 주소로 시험 메일 보내기」는 지금 품에 적힌 값으로 관리자 자신의 주소에 실제 한 통을 보내고 결과를 그 자리에 보여 줍니다. 저장하기 전에 릴레이를 확인할 수 있고, 비밀번호를 비워 두면 저장된 것을 씁니다. 릴레이 설정은 한 번에 맞는 일이 드무니 켜기 전에 한 번 보내 보세요. 실패 문구는 릴레이의 답 그대로입니다.

발송 기록. 같은 탭 아래에 건물 밖으로 나가려 한 메일이 시도마다 한 줄로 남습니다 — 언제, 어떤 이벤트로, 누구에게, 제목이 무엇이었고, 되었는지 안 되었는지. 성공도 남겨서 「안 왔다」는 문의에 답할 수 있고, 본문은 담지 않습니다. `GET /api/v1/admin/mail/deliveries` 로도 읽을 수 있으며, 보존 기간은 「보존 정책」의 감사 로그와 같습니다.

4. 계정과 권한

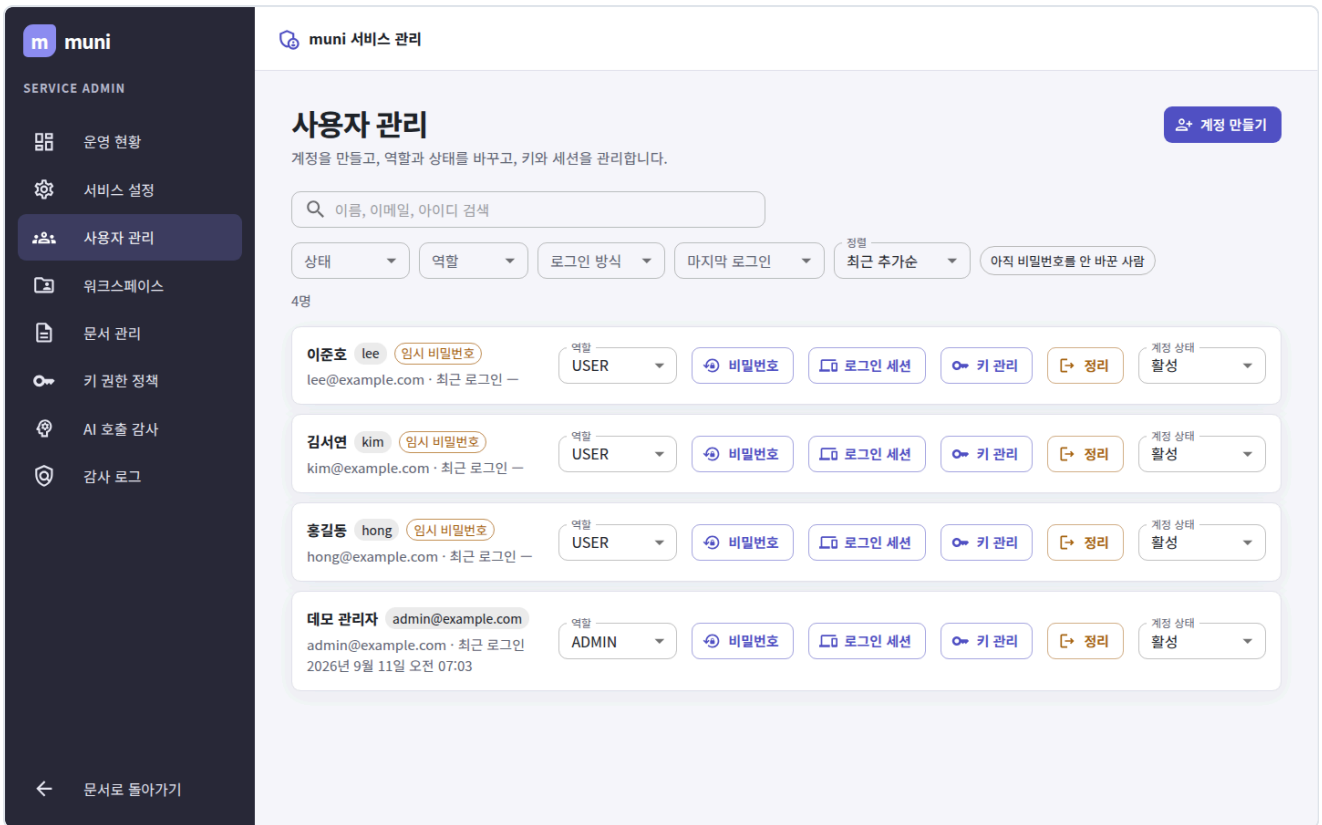
역할

muni 의 권한은 세 층입니다.

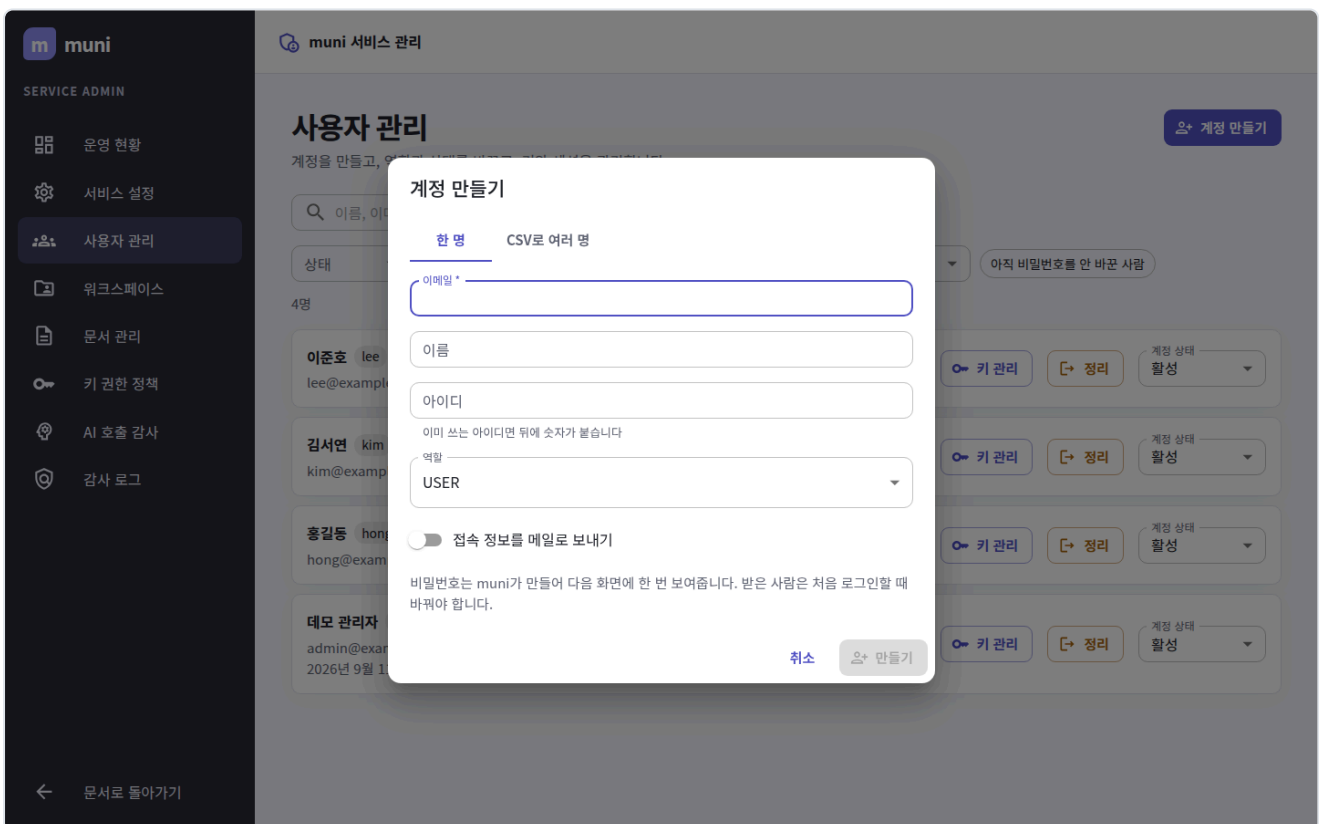
층	값	뜻
서비스 역할	ADMIN / USER	ADMIN 만 「서비스 관리」에 들어갑니다
워크스페이스 역할	OWNER / MANAGER / MEMBER / VIEWER	구성원 관리는 OWNER 와 MANAGER (그리고 서비스 ADMIN)가 합니다. MANAGER 는 다른 사람을 MANAGER 로 올릴 수 없습니다
문서 ACL	OWNER / EDITOR / COMMENTER / VIEWER	문서마다 사람에게 주는 권한. 조회·검색·AI·MCP·공동편집에 똑같이 적용 됩니다

서비스 ADMIN 이라고 해서 남의 문서 본문이 저절로 보이지는 않습니다. 관리 화면에서 하는 일은 소유권 이전과 권한 보기이고, 그 동작은 감사 로그에 남습니다.

계정 만들기



사용자 관리 — 상태·역할·로그인 방식으로 거르고 계정마다 비밀번호·세션·키를 다룬다



계정 만들기 — 한 명씩 만들거나 CSV 로 한꺼번에 가져온다

- 비밀번호를 비워 두면 muni 가 만들어 그 화면에서 한 번만 보여 줍니다. 해시로만 보관하므로 나중에 다시 꺼낼 수 없습니다.
- SMTP 를 설정해 두었다면 「접속 정보를 메일로 보내기」로 본인에게 바로 보낼 수 있습니다.
- 남이 정한 비밀번호로는 로그인만 됩니다. 받은 사람이 바꾸기 전까지 할 수 있는 일은 자기 정보 확인·비밀번호 변경·로그아웃뿐이고, 서버에서 막으므로 API 로 우회할 수 없습니다. 목록의 「임시 비밀번호」 표시가 아직 바뀌지 않은 사람입니다.
- CSV 는 첫 줄에 열 이름을 넣습니다. email 만 필수이고 username · displayName · role 은 있으면 씁니다. 한글 열 이름 (이메일 · 이름 · 역할)도 받습니다. 한 번에 500행, 2MB 까지입니다.
- 계정마다 비밀번호 재설정 · 로그인 세션 확인과 강제 종료 · 키 관리 · 정리(퇴사자 처리) · 상태 변경을 할 수 있습니다. 퇴사자 처리는 계정을 지우지 않고 문서와 결재를 넘깁니다 — 절차는 운영 안내의 「퇴사자 정리」에 있습니다.

키 권한 정책

m muni

SERVICE ADMIN

🏠 운영 현황

⚙️ 서비스 설정

👤 사용자 관리

📁 워크스페이스

📄 문서 관리

🔑 키 권한 정책

🔍 AI 호출 감사

🔒 감사 로그

← 문서로 돌아가기

muni 서비스 관리

키 권한 정책

역할별 개인 키 관리 권한을 운영 중에도 변경할 수 있습니다.

ADMIN

☐ 내 키 조회
key:read:own

☐ 내 키 회전
key:rotate:own

☐ 내 과거 키 폐기
key:revoke:own

☒ 모든 사용자 키 조회
key:read:any

☒ 모든 사용자 키 회전
key:rotate:any

☒ 모든 사용자 키 폐기
key:revoke:any

☒ 키 정책 관리
policy:manage

정책 저장

USER

☒ 내 키 조회
key:read:own

☒ 내 키 회전
key:rotate:own

☒ 내 과거 키 폐기
key:revoke:own

☐ 모든 사용자 키 조회
key:read:any

☐ 모든 사용자 키 회전
key:rotate:any

☐ 모든 사용자 키 폐기
key:revoke:any

☐ 키 정책 관리
policy:manage

정책 저장

키 권한 정책 — 역할마다 개인 키를 다룰 수 있는 범위를 정한다

사용자별 data key 를 누가 조회·회전·폐기할 수 있는지 역할별로 운영 중에 바꿉니다. 기본값은 USER 는 자기 키만 (key:read:own · key:rotate:own · key:revoke:own), ADMIN 은 모든 사용자 키 (key:*:any)와 정책 관리 (policy:manage)입니다. policy:manage 는 ADMIN 에서 뺄 수 없습니다 — 뺄 수 있다면 아무도 정책을 되돌리지 못합니다.

워크스페이스와 문서

m muni

SERVICE ADMIN

☰ 운영 현황

⚙ 서비스 설정

👤 사용자 관리

📁 워크스페이스

📄 문서 관리

🔑 권한 정책

🧠 AI 호출 감사

🔒 감사 로그

← 문서로 돌아가기

muni 서비스 관리

워크스페이스

문서 수와 마지막 편집 시각으로 쓰이고 있는 곳과 비어 있는 곳을 구분합니다.

🔍 이름 또는 slug로 찾기

범위
사용 중

팀

데모 회사 기획팀 /demo-plan

마지막 편집 2026년 9월 11일 오전 07:03

소유권 이전

정리

소유자 데모 관리자 · 구성원 1명 · 문서 5개

개인

이준호의 문서 /personal-12994c33-eae8-468b-a4fa-c7665a085a47

편집된 문서 없음

소유자 이준호 · 구성원 1명 · 문서 0개

개인

김서연의 문서 /personal-e0f93f41-0eef-4532-b75b-c40a9dcf591e

편집된 문서 없음

소유자 김서연 · 구성원 1명 · 문서 0개

개인

홍길동의 문서 /personal-ce4f4fa7-8f1d-4a0f-b158-5d24d5be2ef6

편집된 문서 없음

소유자 홍길동 · 구성원 1명 · 문서 0개

개인

admin@example.com의 문서 /personal-9b7ac95f-ba65-484a-89d6-ebc260ffdf1f

편집된 문서 없음

소유자 데모 관리자 · 구성원 1명 · 문서 0개

워크스페이스 관리 — 워크스페이스마다 소유자와 구성원·문서 수를 보고 소유권을 넘긴다

m muni

SERVICE ADMIN

☰ 운영 현황

⚙ 서비스 설정

👤 사용자 관리

📁 워크스페이스

📄 문서 관리

🔑 권한 정책

🧠 AI 호출 감사

🔒 감사 로그

← 문서로 돌아가기

muni 서비스 관리

문서 관리

소유자가 떠난 문서를 넘기고, 휴지통에 있는 문서를 완전히 지웁니다.

🔍 제목 또는 소유자로 찾기

범위
사용 중

2026년 상반기 사업계획

데모 회사 기획팀 · 소유자 데모 관리자 · rev 3 · 2026년 9월 11일 오전 07:03

권한 보기

소유권 이전

신규 입사자 온보딩 안내

데모 회사 기획팀 · 소유자 데모 관리자 · rev 1 · 2026년 9월 11일 오전 07:03

권한 보기

소유권 이전

월간 운영 보고 (2월)

데모 회사 기획팀 · 소유자 데모 관리자 · rev 1 · 2026년 9월 11일 오전 07:03

권한 보기

소유권 이전

문서 작성 가이드라인

데모 회사 기획팀 · 소유자 데모 관리자 · rev 1 · 2026년 9월 11일 오전 07:03

권한 보기

소유권 이전

제품 회의록 (3월 2주)

데모 회사 기획팀 · 소유자 데모 관리자 · rev 1 · 2026년 9월 11일 오전 07:03

권한 보기

소유권 이전

문서 관리 — 소유자가 떠난 문서를 넘기고, 휴지통에 있는 문서를 완전히 지운다

- 워크스페이스 화면은 문서 수와 마지막 편집 시각으로 쓰이는 곳과 빈 곳을 구분해 줍니다. 「소유권 이전」으로 떠난 사람의 워크스페이스를 넘기고, 「정리」로 쓰지 않는 워크스페이스를 치웁니다(범위를 바꾸면 되살릴 수 있습니다).
- 문서 관리의 「권한 보기」는 그 문서를 실제로 볼 수 있는 사람 전부를 보여 줍니다 — 직접 공유, 워크스페이스 구성원, 공개 링크까지 한 화면에서 확인합니다. "이 문서 누가 볼 수 있나요" 라는 질문에 답하는 자리입니다.

5. 운영

상태 점검

엔드포인트	메서드	인증	무엇을 답하나
/healthz	GET	없음	프로세스가 살아 있는가
/readyz	GET	없음	데이터베이스까지 붙어 요청을 받을 수 있는가
/metrics	GET	관리자	Prometheus 노출 형식
/api/v1/admin/overview	GET	관리자	관리 화면 「운영 현황」이 쓰는 요약

SERVICE ADMIN

- 운영 현황
- 서비스 설정
- 사용자 관리
- 워크스페이스
- 문서 관리
- 키 권한 정책
- AI 호출 감사
- 감사 로그

muni 서비스 관리

운영 현황

muni v0.36.0 · commit none

사용

사용자
4
활성 4 · 관리자 1

정지된 계정
0

최근 7일 로그인
1

워크스페이스
5

문서
5
유지통 0 · 버전 7

이번 주
5
새 문서 5

저장과 접근

첨부 파일
0
0 B

열린 세션
1

사용 중인 API key
0

승인 대기 문서
0

연결 상태

설정에 적힌 내용을 확인한 결과입니다. 실제 연결 시험은 각 설정 화면의 연결 테스트 버튼으로 합니다.

- ✓ 데이터베이스 마이그레이션 016_page_orientation
- ⊖ AI 비활성 [설정](#)
- ⊖ OIDC SSO 로컬 로그인만 사용 [설정](#)
- ⊖ 발표자료 연동 설정되지 않음 [설정](#)
- ✓ PDF 내보내기 /usr/bin/chromium-browser [설정](#)
- ✓ 저장 용량 데이터베이스 9.7 MB · 첨부 0 B

최근 활동 [전체 보기](#)

- SEARCH_DOCUMENT 데모 관리자 2026년 9월 11일 오전 07:03
- SEARCH_DOCUMENT 데모 관리자 2026년 9월 11일 오전 07:03
- UPDATE_DOCUMENT 데모 관리자 2026년 9월 11일 오전 07:03
- UPDATE_DOCUMENT 데모 관리자 2026년 9월 11일 오전 07:03
- CREATE_COMMENT 데모 관리자 2026년 9월 11일 오전 07:03
- SHARE_DOCUMENT 데모 관리자 2026년 9월 11일 오전 07:03
- CREATE_DOCUMENT 데모 관리자 2026년 9월 11일 오전 07:03
- CREATE_DOCUMENT 데모 관리자 2026년 9월 11일 오전 07:03

운영 현황 — 사용량·저장과 접근·연결 상태·최근 활동을 한 화면에서 본다

「연결 상태」는 설정에 적힌 내용을 확인한 결과이고, 실제 연결 시험은 각 설정 탭의 연결 테스트 단추로 합니다. 「최근 활동」은 감사 로그의 앞부분입니다.

/metrics 는 사용자 수·문서 수가 들어 있어 관리자 인증을 요구합니다. Prometheus 로 쿼하려면 api:read 권한의 관리자 API 키를 만들어 authorization.credentials 에 넣습니다. 지표 목록은 [운영 안내](#)의 「지표 수집」에 있습니다.

백업

상태는 데이터베이스와 ENCRYPTION_KEY 둘뿐입니다. 이미지에는 상태가 없습니다.

```
docker compose exec -T postgres \
  pg_dump -U muni -d muni --format=custom --compress=9 \
  > muni-$(date +%Y%m%d).dump
```

키는 백업과 다른 곳에 보관합니다. 복원 절차와 "복원해 본 적 없는 백업은 백업이 아니다"는 확인 방법은 [운영 안내](#)에 있습니다.

감사 로그

The screenshot shows the '감사 로그' (Audit Log) page in the Muni Service Admin interface. The left sidebar contains navigation links: 'm muni', 'SERVICE ADMIN', '운영 현황', '서비스 설정', '사용자 관리', '워크스페이스', '문서 관리', '키 권한 정책', 'AI 호출 감사', and '감사 로그'. The main content area is titled 'muni 서비스 관리' and '감사 로그'. Below the title is a description: '로그인, 문서 접근, 공유, AI, MCP와 관리자 동작을 추적합니다.' There are filters for '검색' (Search), '대상' (Target), '정확한 동작' (Exact Action), '시작' (Start) date, and '끝' (End) date. A 'CSV 내려받기' (Download CSV) button is present. The log entries are as follows:

Action Type	User	Target	Timestamp
SEARCH_DOCUMENT	데모 관리자 · SEARCH	— · 127.0.0.1/32	2026년 9월 11일 오전 07:03
SEARCH_DOCUMENT	데모 관리자 · SEARCH	— · 127.0.0.1/32	2026년 9월 11일 오전 07:03
READ_DOCUMENT	데모 관리자 · DOCUMENT	935f1c0d-1b70-44e9-ad22-7eb4417a44c7 · 127.0.0.1/32	2026년 9월 11일 오전 07:03
UPDATE_DOCUMENT	데모 관리자 · DOCUMENT	935f1c0d-1b70-44e9-ad22-7eb4417a44c7 · 127.0.0.1/32	2026년 9월 11일 오전 07:03
READ_DOCUMENT	데모 관리자 · DOCUMENT	935f1c0d-1b70-44e9-ad22-7eb4417a44c7 · 127.0.0.1/32	2026년 9월 11일 오전 07:03
READ_DOCUMENT	데모 관리자 · DOCUMENT	935f1c0d-1b70-44e9-ad22-7eb4417a44c7 · 127.0.0.1/32	2026년 9월 11일 오전 07:03
UPDATE_DOCUMENT	데모 관리자 · DOCUMENT	935f1c0d-1b70-44e9-ad22-7eb4417a44c7 · 127.0.0.1/32	2026년 9월 11일 오전 07:03

감사 로그 — 대상·동작·기간으로 거르고 CSV 로 내려받는다

로그인, 문서 읽기·수정, 공유, AI·MCP 호출, 관리자 동작이 행위자·대상·IP·시각과 함께 남습니다. 「CSV 내려받기」로 그대로 내보낼 수 있습니다. AI 호출만 따로 보려면 「AI 호출 감사」 화면을 씁니다(AI 를 켜지 않았다면 비어 있습니다). 보존 기간은 서비스 설정의 보존 정책에서 정합니다.

업그레이드

```
gzip -dc muni-v<새 버전>.tar.gz | docker load
# compose.example.yaml 의 image 태그를 새 버전으로 바꾼 뒤
docker compose -f compose.example.yaml --env-file .env up -d
curl -fsS http://127.0.0.1:8080/readyz
```

기동할 때 마이그레이션이 자동으로 적용됩니다. **올리기 전에 백업을 받으세요.** 되돌릴 때는 이미지 태그를 옛 버전으로 되돌립니다 — 다만 마이그레이션은 되돌아가지 않으므로, 새 버전이 스키마를 바꿨다면 **그 백업으로 복원**해야 합니다. 백업보다 새로운 이미지로 복원하는 방향은 되지만, 구버전 이미지로 신버전 데이터를 여는 방향은 지원하지 않습니다.

6. 장애 대응

증상	확인할 곳	조치
컨테이너가 바로 죽는다	<code>docker compose logs muni</code> 의 <code>invalid startup configuration / invalid encryption key</code>	환경 변수 네 개와 키 형식을 확인합니다
기동 중 멈춘다	<code>database connection failed / database migration failed</code>	DSN, 네트워크, DB 계정의 <code>schema·extension</code> 생성 권한
최초 관리자로 못 들어간다	<code>bootstrap failed</code>	<code>BOOTSTRAP_ADMIN_PASSWORD</code> 가 12자 이상인지, 계정이 이미 있으면 <code>bootstrap</code> 은 덮어쓰지 않습니다
<code>/readyz</code> 만 실패한다	데이터베이스	DB 는 뺐는데 <code>muni</code> 가 못 붙는 상태입니다
Keycloak 에 로그인되어 있는데 로그인 화면이 나온다	Keycloak OIDC 탭의 자동 로그인, 주소의 ? <code>sso=none</code>	자동 로그인은 기본 꺼짐입니다. <code>sso=none</code> 은 Keycloak 이 세션 없음으로 답했다는 표시이고, 같은 탭에서는 한 번만 묻습니다 — 새 탭에서 확인합니다(자동 로그인)
로그인은 되는데 AI 가 안 된다	「운영 현황」의 연결 상태, AI 탭의 연결 테스트	게이트웨이 주소·키, AI 연결 테스트는 실제 호출 endpoint 와 적용된 보정을 함께 보여 줍니다
「메일이 안 왔다」	「메일 알림」 탭의 발송 기록	그 사람 주소로 된 행이 없으면 보내려 한 적이 없는 것입니다 — 스위치가 꺼졌거나, 계정에 이메일이 없거나, 자기가 한 일입니다. 실패 행이 있으면 그 옆의 이유가 릴레이의 답입니다(메일 알림)
시험 메일이 실패한다	시험 발송 단추 옆의 오류 문구	「연결하지 못했습니다」는 주소·포트·방화벽, 「STARTTLS」는 보안 방식을 <code>auto</code> 로, 「암호화되지 않은 연결로는 계정 정보를 보내지 않습니다」는 인증 없는 릴레이면 계정을 비우고 아니면 <code>starttls / tls</code> 로
PDF 내보내기가 느리거나 거절된다	<code>muni_pdf_renders_in_progress</code> 와 <code>muni_pdf_renders_limit</code>	앞 값이 뒤에 붙어 있으면 줄을 선 것입니다. <code>MUNI_PDF_CONCURRENCY</code> 와 메모리를 함께 올립니다
PDF 만 실패한다	로그의 Export 오류, <code>MUNI_CHROMIUM_PATH</code>	<code>read-only</code> 컨테이너에서 <code>/tmp tmpfs</code> 를 뺐는지 확인합니다
특정 문서만 열리지 않는다	「문서 관리」에서 소유자와 휴지통 여부	소유권 이전 또는 복원
디스크가 찬다	보존 정책, <code>muni_attachment_bytes</code>	휴지통·버전 정리는 되돌릴 수 없으니 미리보기로 규모를 먼저 봅니다

증상	확인할 곳	조치
느려졌다는 말이 나온다	<code>muni_http_request_duration_seconds</code> 의 p95	요청 로그(<code>http request</code>)에 경로별 <code>duration_ms</code> 가 남습니다
결재가 며칠째 안 넘어간다	결재자가 퇴사했는지	운영 안내의 「퇴사자 정리」
누가 무엇을 했는지	감사 로그, CSV 내려받기	시각과 문서 ID 로 좁힙니다
「...으로 보내기」가 메뉴에 없다	「문서 넘기기」 탭의 목록과 체크한 형식	목록이 비어 있거나 그 서비스가 Markdown · DOCX 를 받지 않는 것으로 적혀 있으면 나오지 않습니다. DOCX 는 DOCX 내보내기도 켜져 있어야 합니다 (문서 넘기기)
다른 서비스가 보낸 문서가 「허용되지 않은 서비스」로 거절된다	「문서 넘기기」 탭의 주소	상대가 <code>source</code> 로 보내는 오리진이 목록의 주소와 스킴·호스트·포트까지 같아야 합니다. 경로가 붙은 주소는 오리진이 아닙니다

로그는 JSON 한 줄씩 표준출력으로 나갑니다. 모든 요청은 `{"level":"INFO","msg":"http request","method":"GET","path":"/api/v1/...","status":200,"duration_ms":8}` 형태로 남고 (`/healthz` · `/readyz` 는 제외), 기동은 `muni started`, 종료는 `shutdown requested` 입니다.

7. 보안

처음에 반드시 바꿀 것

- `BOOTSTRAP_ADMIN_PASSWORD` — 첫 로그인 뒤 개인 설정에서 바꾸고, `.env` 의 값도 그대로 두지 마세요.
- `ENCRYPTION_KEY` — `.env.example` 의 자리표시자를 그대로 쓰면 안 됩니다. `openssl rand -base64 32`.
- `POSTGRES_DSN` 의 데이터베이스 비밀번호.
- Kubernetes 예제 `deploy/kubernetes/muni.yaml` 의 Secret 은 자리표시자입니다. 실제 배포에서는 외부 secret 관리로 주입하세요.

밖에 열지 말 것

- 컨테이너의 `8080` 을 인터넷에 직접 열지 말고 `ingress/reverse proxy` 뒤에 두고 TLS 를 거기서 끝냅니다.
- PostgreSQL 포트는 muni 만 달게 합니다.
- `/metrics` 는 관리자 인증이 걸려 있지만, 그래도 사내 모니터링 망에서만 달게 두세요.

정책으로 조일 수 있는 것 (서비스 설정 → 보안·내보내기)

- 공개 링크 허용 여부 — 링크를 가진 사람이 누구인지 muni 는 알지 못합니다.
- PDF·DOCX 내보내기 허용 여부.

- 세션 유지 시간, API 키 최대 수명, 업로드 크기 상한, 읽기 감사 로그.
- 로컬 로그인 끄기(일반 탭) — SSO 만 쓰는 조직이면 끕니다.

기본으로 켜져 있는 것

- 비밀번호는 Argon2id 로, 세션·API 토큰은 SHA-256 으로 저장하고 쿠키는 HttpOnly·SameSite 입니다.
- OIDC·AI·SMTP·Ptium 비밀번호와 사용자 data key 는 AES-256-GCM 으로 봉인합니다.
- 컨테이너는 비 root·read-only 루트 파일 시스템·capability 전부 drop 으로 돕니다.
- 모든 페이지는 `script-src 'self'` 의 콘텐츠 보안 정책을 답니다. 방문 추적을 켜도 요청마다 다른 nonce 와 스니펫이 적은 출처만 더해지고 `'unsafe-inline'` 은 넣지 않습니다([방문 추적](#)).
- 가져오기는 남이 만든 파일을 읽는 일이라, 압축 폭탄·과도한 XML 중첩을 크기와 깊이로 막고 `javascript:` 같은 링크를 버리며 파일이 가리키는 원격 주소를 대신 내려받지 않습니다(SSRF 방지).

더 깊은 절차: [운영 안내](#) · 전체 구조: [아키텍처](#) · API 와 MCP: [MCP 안내](#) 와 `/api/openapi.yaml`